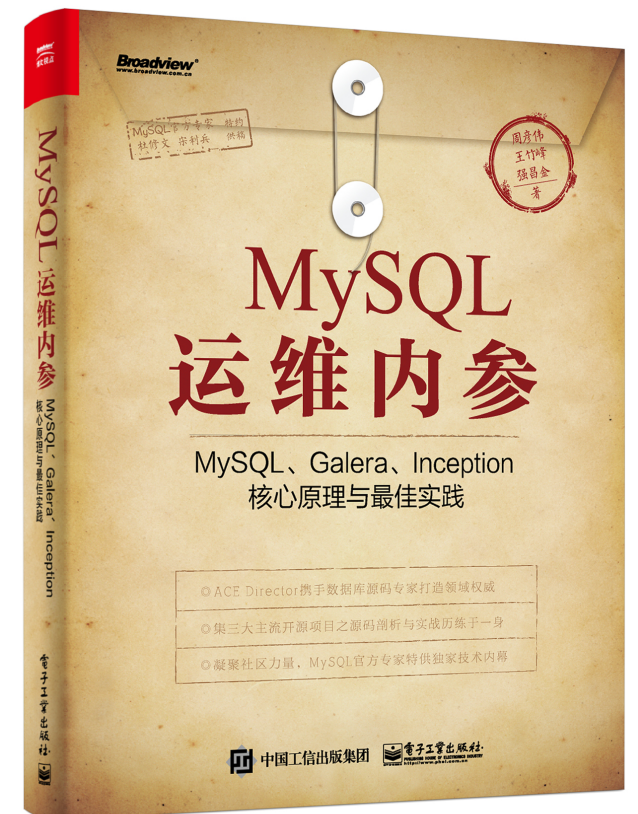


个人简介



DBA团队
负责人

Oracle ACE
1/16

MySQL
运维内参
10000+

Inception开源
90%

大纲

- ▶ 背景
- ▶ 客户端行为
- ▶ 服务器验证
- ▶ 总结
- ▶ 思考

背景

```
mysql> select user,host>Password from mysql.user where user = 'zhufeng';
```

user	host	Password
zhufeng	127.0.0.1	*6183D652370F314C1F8E29D904CFDC3DA25C6D33

```
1 row in set (0.01 sec)
```

- ▶ 单方保存
- ▶ 无法解密的密文
- ▶ 抓包看客户端与服务器的行为, `sudo ngrep -x -q -d lo '' 'host 127.0.0.1'`

➔ data sudo ngrep -x -q -d lo0 '' 'port 3307'

interface: lo0 (127.0.0.0/255.0.0.0)

filter: (ip or ip6) and (port 3307)

T 127.0.0.1:3307 -> 127.0.0.1:55750 [AP]

57	00	00	00	0a	35	2e	37	2e	32	31	2d	32	30	2d	64	W....5.7.21-20-d
65	62	75	67	2d	6c	6f	67	00	03	00	00	00	7e	64	7d	ebug-log.....~d}
65	37	62	50	13	00	ff	f7	21	02	00	ff	81	15	00	00	e7bP.....!.....
00	00	00	00	00	00	00	00	01	3d	30	42	31	29	70	5c	=0B1)p\
50	19	01	75	00	6d	79	73	71	6c	5f	6e	61	74	69	76	P..u.mysql_nativ
65	5f	70	61	73	73	77	6f	72	64	00						e_password.

T 127.0.0.1:55750 -> 127.0.0.1:3307 [AP]

cc	00	00	01	05	a6	7f	00	00	00	00	01	21	00	00	00	!....
00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	00	
00	00	00	00	7a	68	75	66	65	6e	67	2e	77	61	6e	67	zhufeng.wang
00	14	cb	70	a0	f3	40	18	7a	52	d1	ce	bf	7a	c4	11	...p..@.zR...z..
b8	02	39	88	ed	7f	6d	79	73	71	6c	5f	6e	61	74	69	..9...mysql_nati
76	65	5f	70	61	73	73	77	6f	72	64	00	73	03	5f	6f	ve_password.s._o
73	08	6f	73	78	31	30	2e	31	32	0c	5f	63	6c	69	65	s.osx10.12._clie
6e	74	5f	6e	61	6d	65	08	6c	69	62	6d	79	73	71	6c	nt_name.libmysql
04	5f	70	69	64	05	34	31	34	31	35	0f	5f	63	6c	69	._pid.41415._cli
65	6e	74	5f	76	65	72	73	69	6f	6e	10	49	6e	63	65	ent_version.Ince
70	74	69	6f	6e	20	33	2e	33	2e	31	35	09	5f	70	6c	ption 3.3.15._pl
61	74	66	6f	72	6d	06	78	38	36	5f	36	34	0c	70	72	atform.x86_64.pr
6f	67	72	61	6d	5f	6e	61	6d	65	05	6d	79	73	71	6c	ogram_name.mysql

T 127.0.0.1:3307 -> 127.0.0.1:55750 [AP]

07	00	00	02	00	00	00	02	00	00	00						
----	----	----	----	----	----	----	----	----	----	----	--	--	--	--	--	-------

权限验证

携带信息

连接发起者/建立TCP/IP连接

等待scramble

客户端加工

一系列计算新密码

发送新密码

等待验证结果

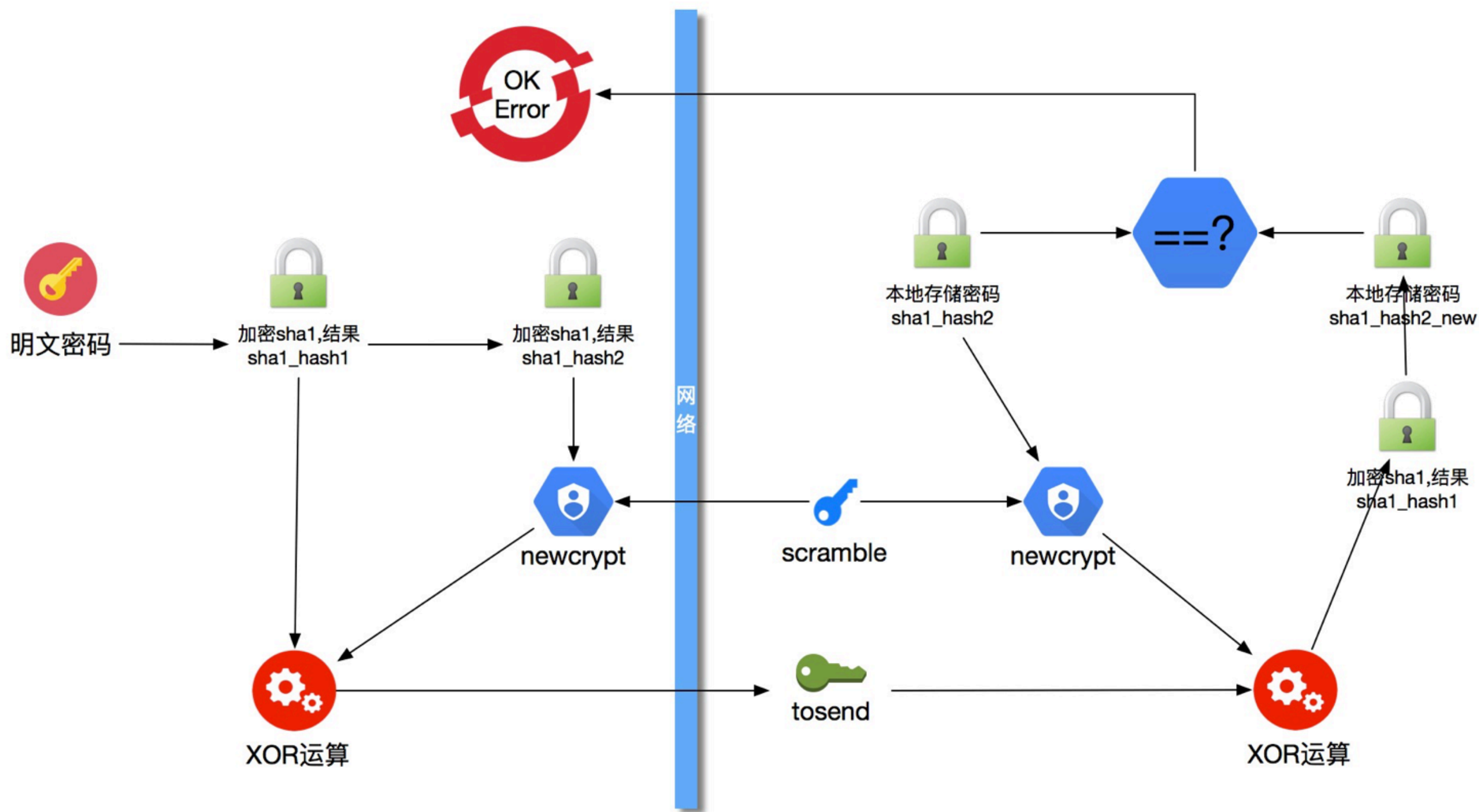
发送scramble

等待新密码

一系列运算——解密

与本地mysql.user中相应信息比对

返回给客户端验证结果



总结

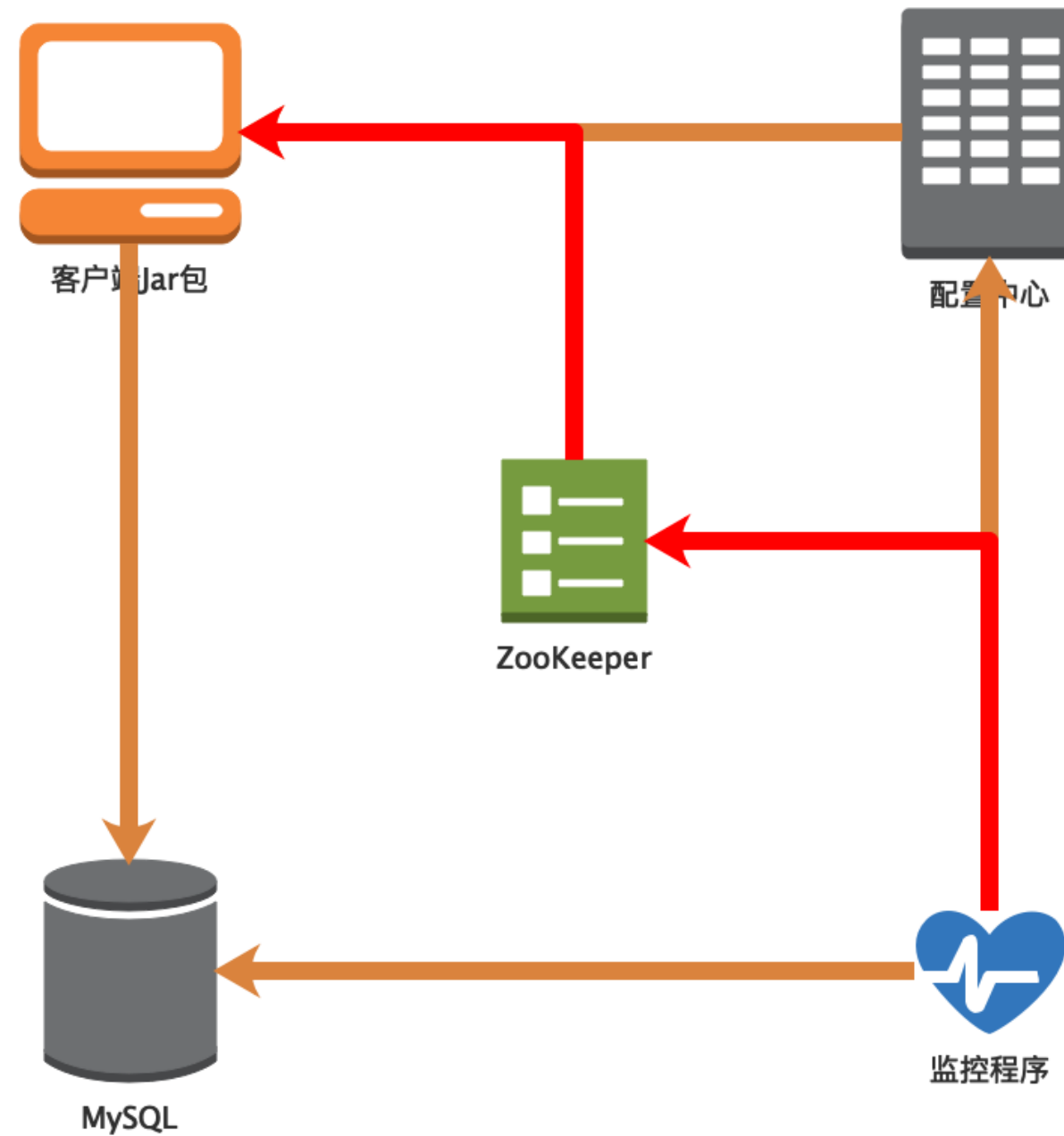
- ▶ 网络中不会传输明文
- ▶ 每次验证scramble都不同
- ▶ 传输的密码是经过多次加密，并且与scramble运算过的，都不同
- ▶ 密码明文只会在客户端出现，连MySQL服务器自身都不知道
- ▶ 其它用途？

思考

- ▶ 伪装一个服务器可否破解MySQL密码?
- ▶ 中间层实现方法零 (☆) —— 解决方案，不易推广
- ▶ 中间层实现方法一 (☆) —— haproxy
- ▶ 中间层实现方法二 (☆) —— 权限无限放大
- ▶ 中间层实现方法三 (☆☆) —— 多入口
- ▶ 中间层实现方法四 (☆☆☆☆) —— 不同scramble
- ▶ 中间层实现方法五 (☆☆☆☆) —— 相同scramble
- ▶ 中间层实现方法六 (☆☆☆☆☆) —— 以假乱真

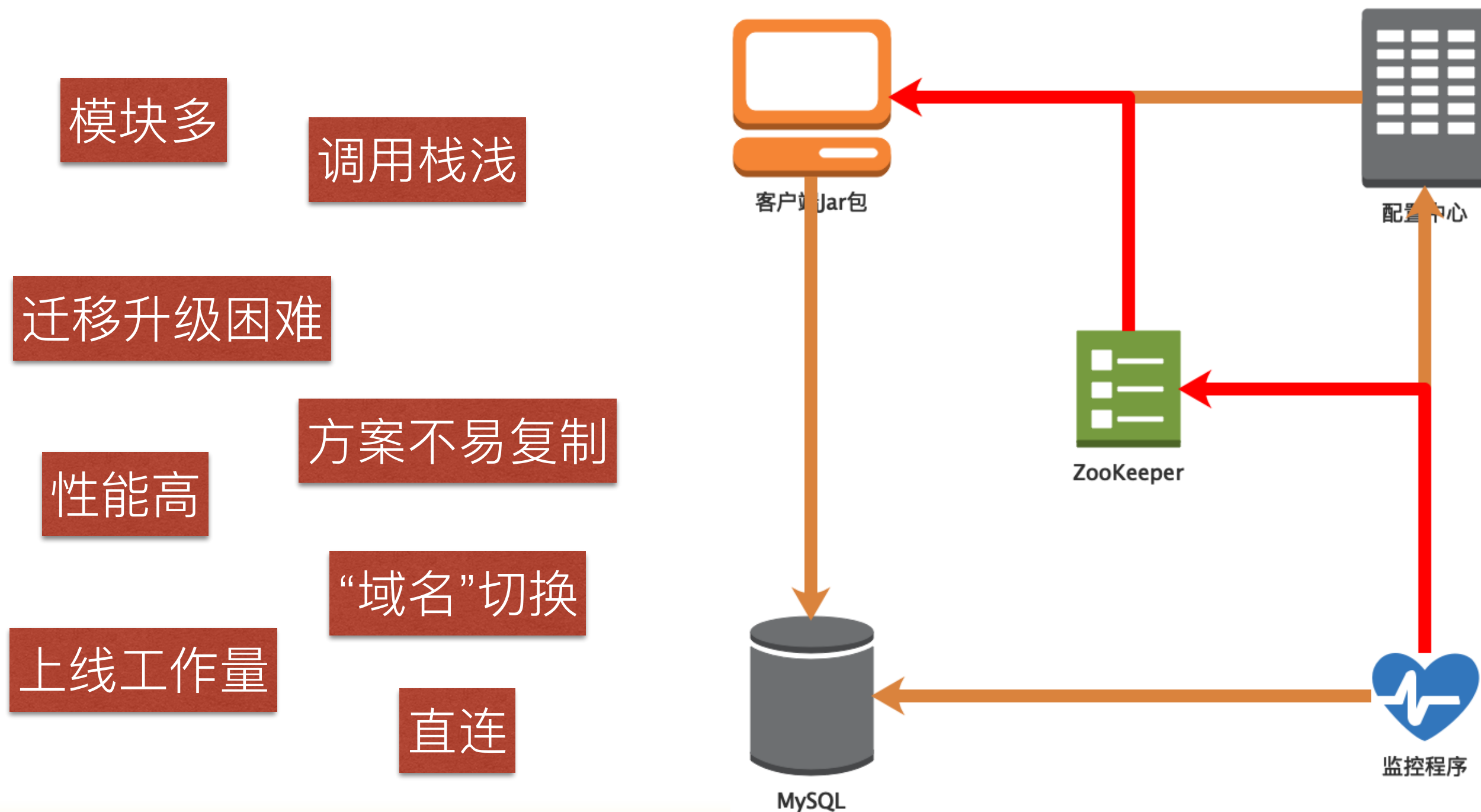
思考

中间层实现方法零 (☆) —— 解决方案，不易推广



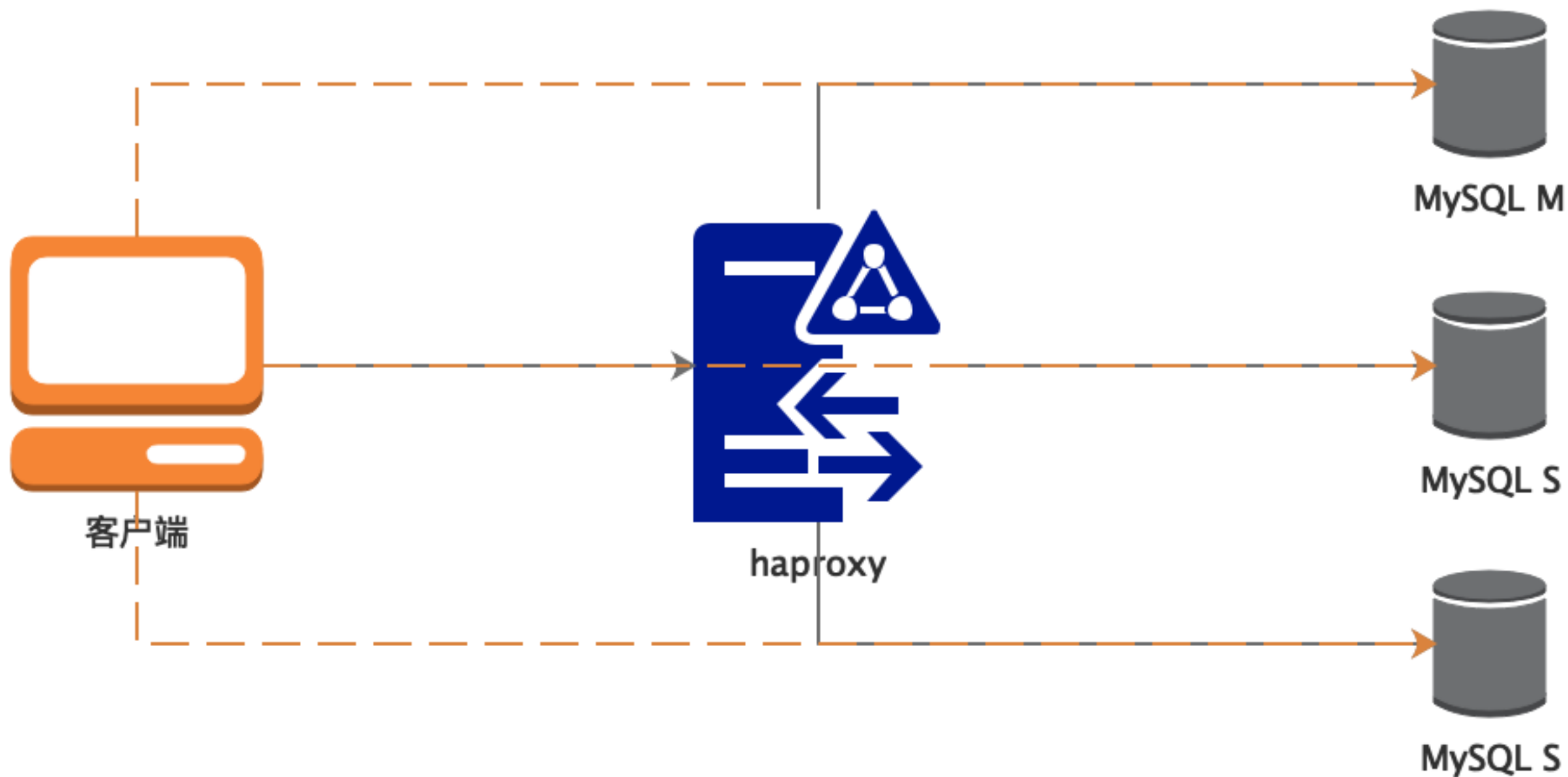
思考

中间层实现方法零 (☆) —— 解决方案，不易推广



思考

中间层实现方法一 (☆) ——haproxy



思考

中间层实现方法一 (☆) ——haproxy

仅仅是中间层

啥也做不了

能--看到客户端IP+用户名

下线节点不优雅

权限放大? 是的

谁连接了谁?

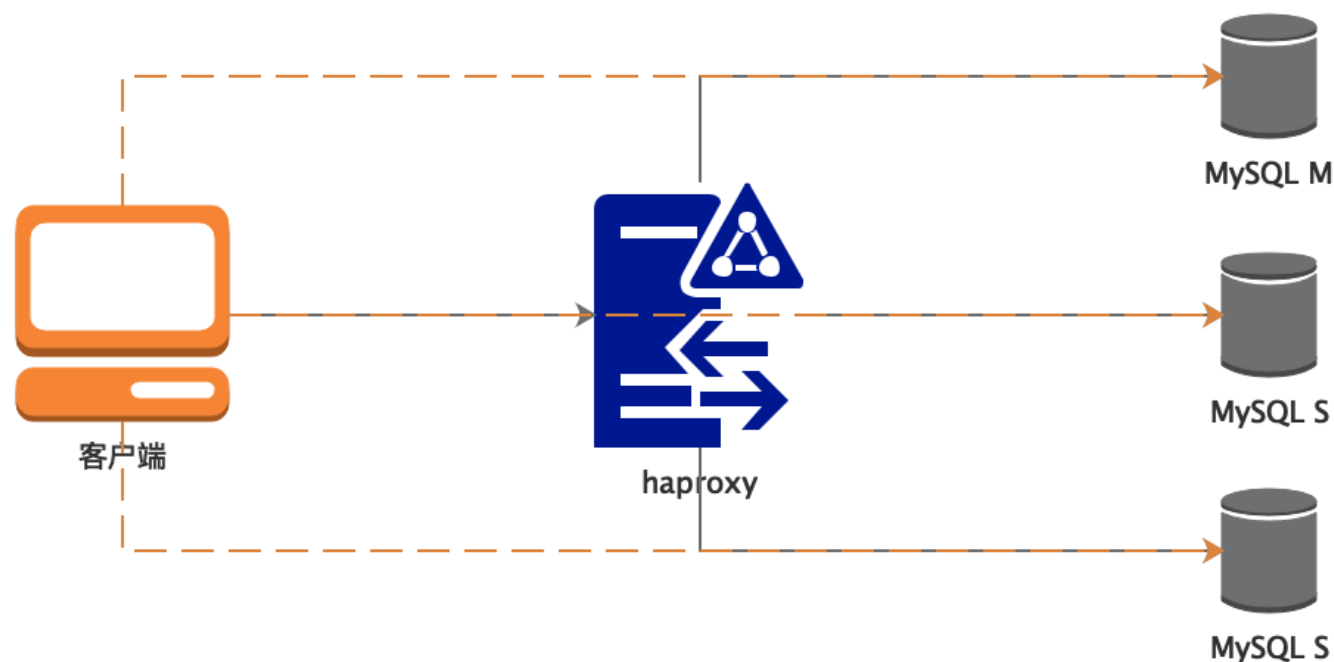
类似直连

谁感知多端口

连接节点一对一

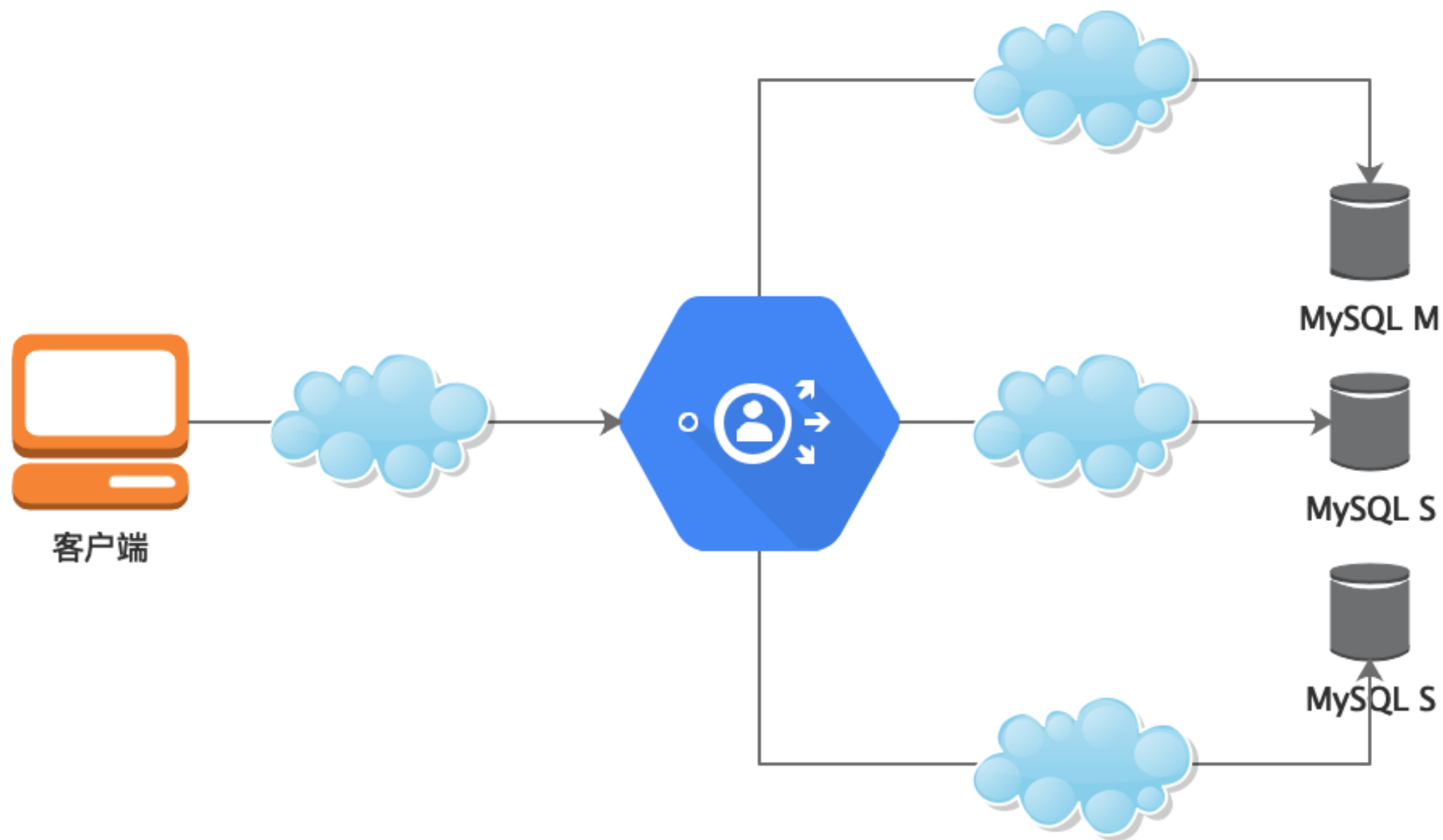
负载均衡

不能自动重连



思考

中间层实现方法二 (☆) —— 权限无限放大



思考

中间层实现方法二 (☆) —— 权限无限放大

权限无限放大

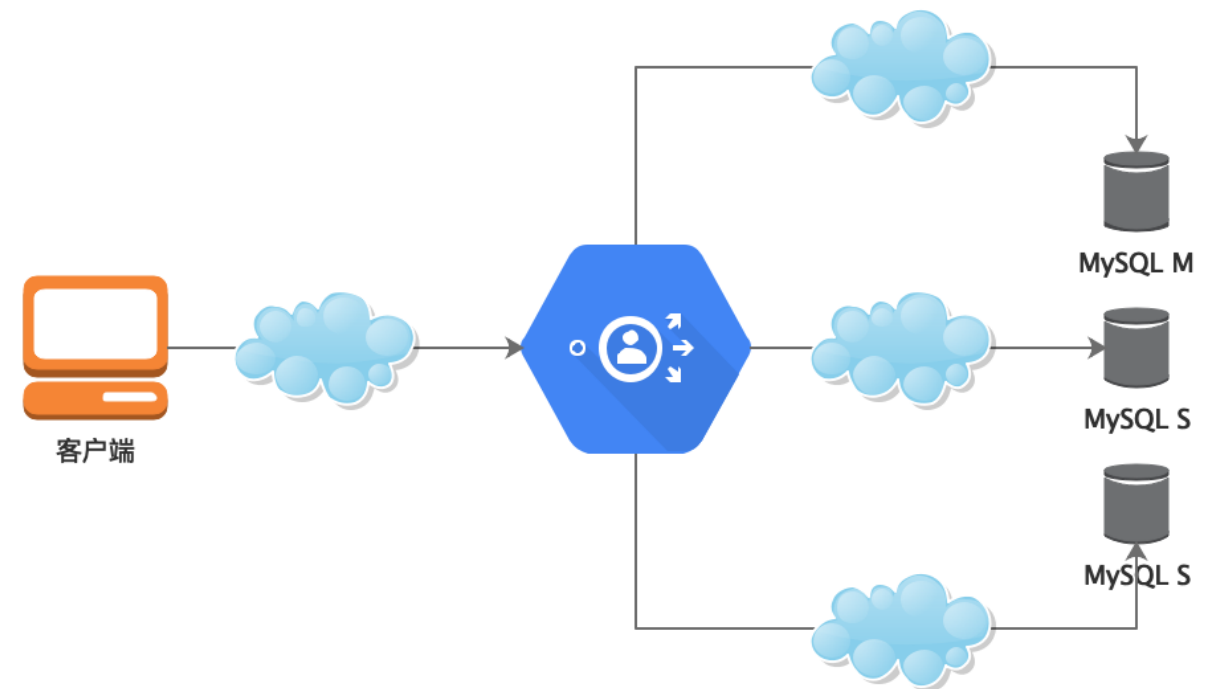
任意连接

中间层用户名

中间层有了管理功能

负载均衡

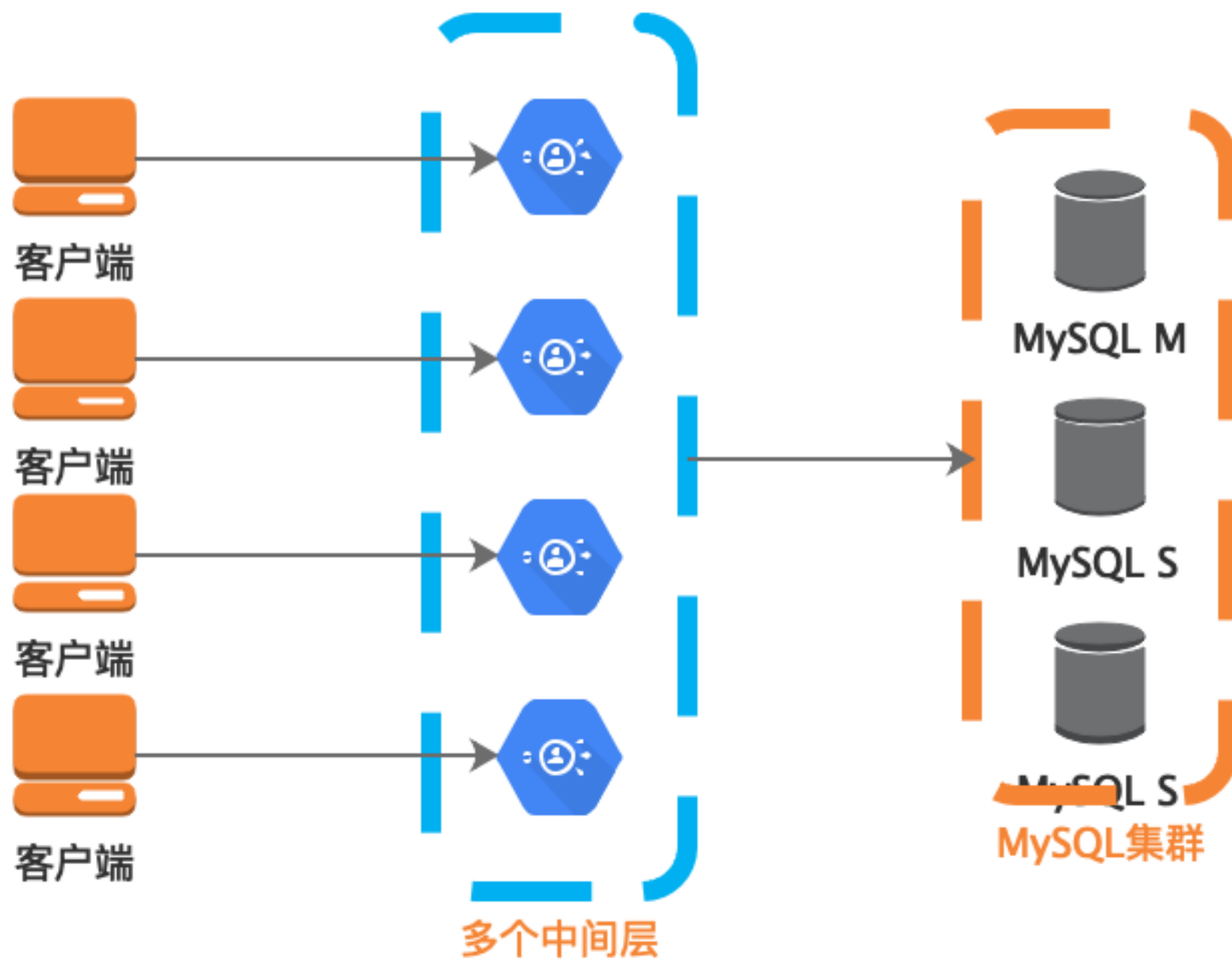
看到中间层IP



算是一个真正意义的MySQL中间层了

思考

中间层实现方法三 (☆) ——多入口



思考

中间层实现方法三 (☆) —— 多入口

解决部分权限放大

只有中间层IP

中间层配置变更困难

占用很多资源

中间层用户名

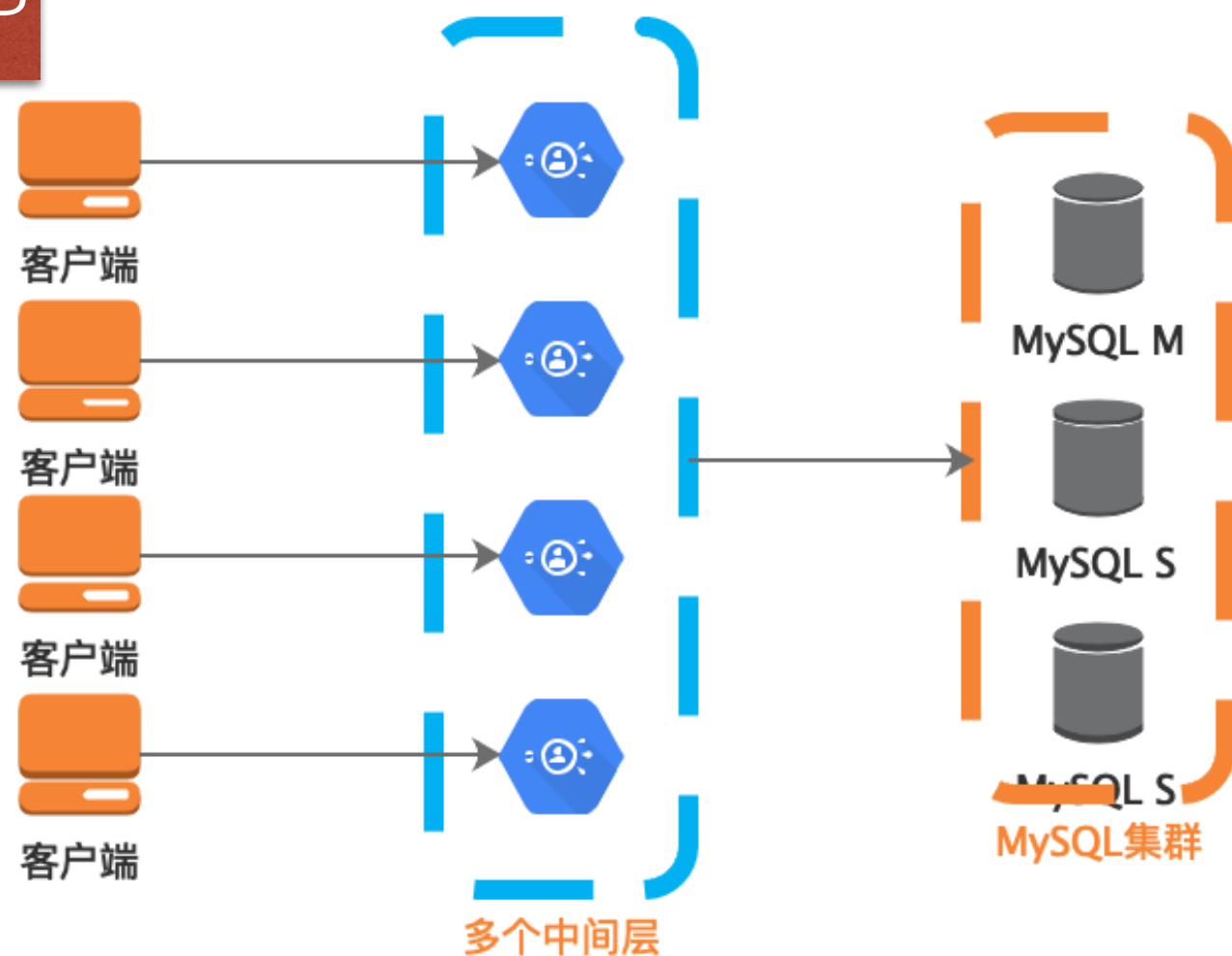
任意连接

客户端IP验证

中间层流量不均匀

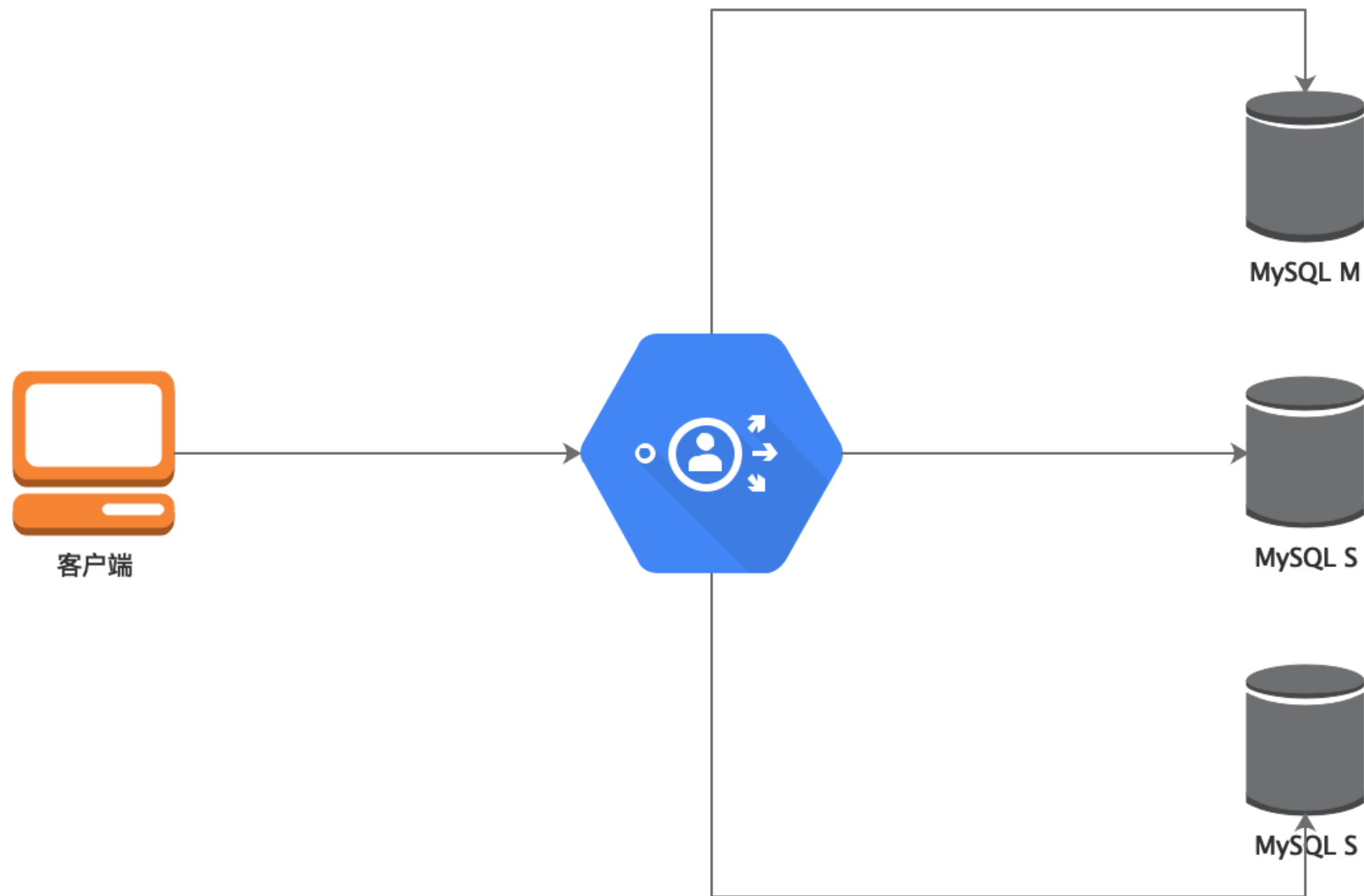
中间层维护困难

暴露高级账号密码



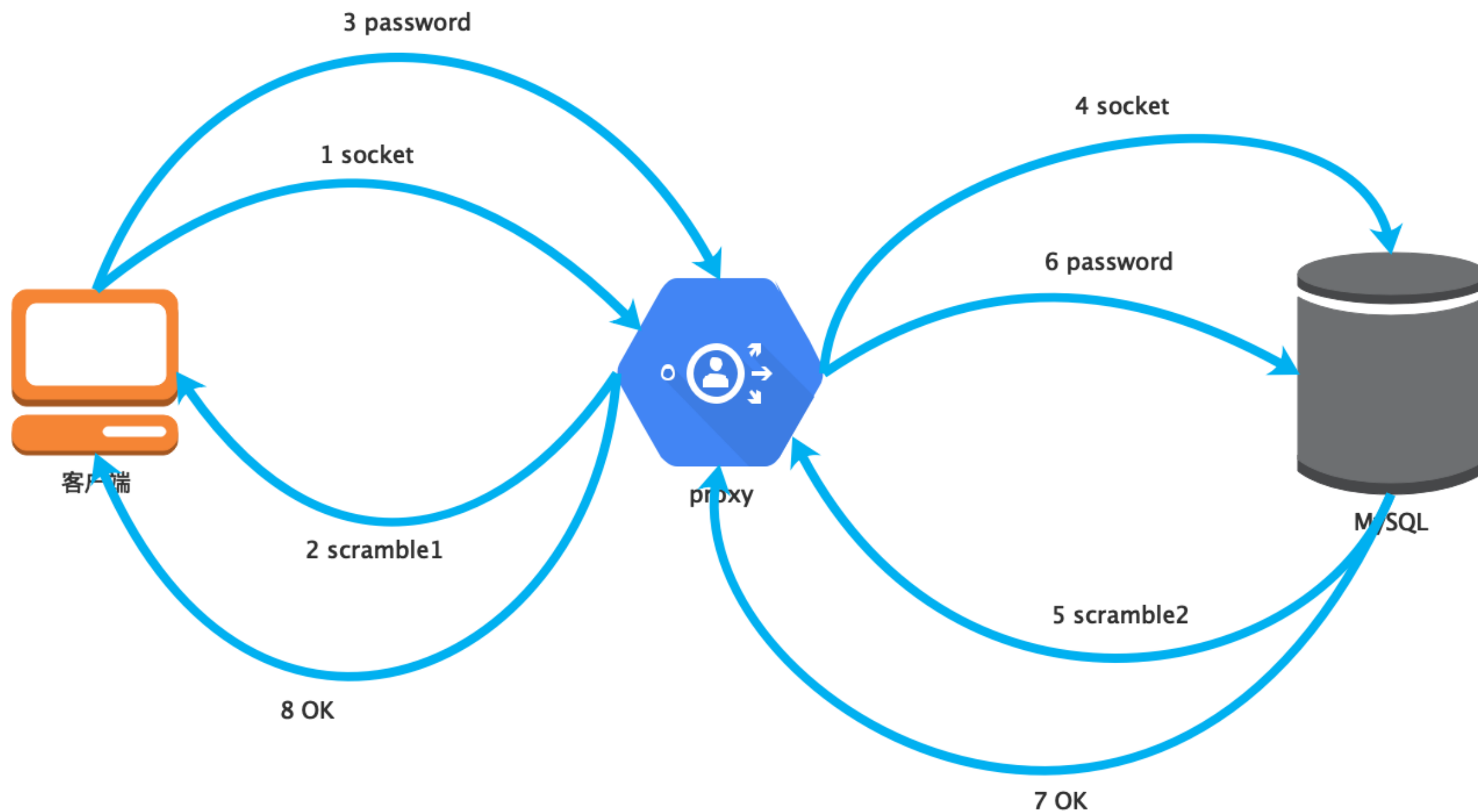
思考

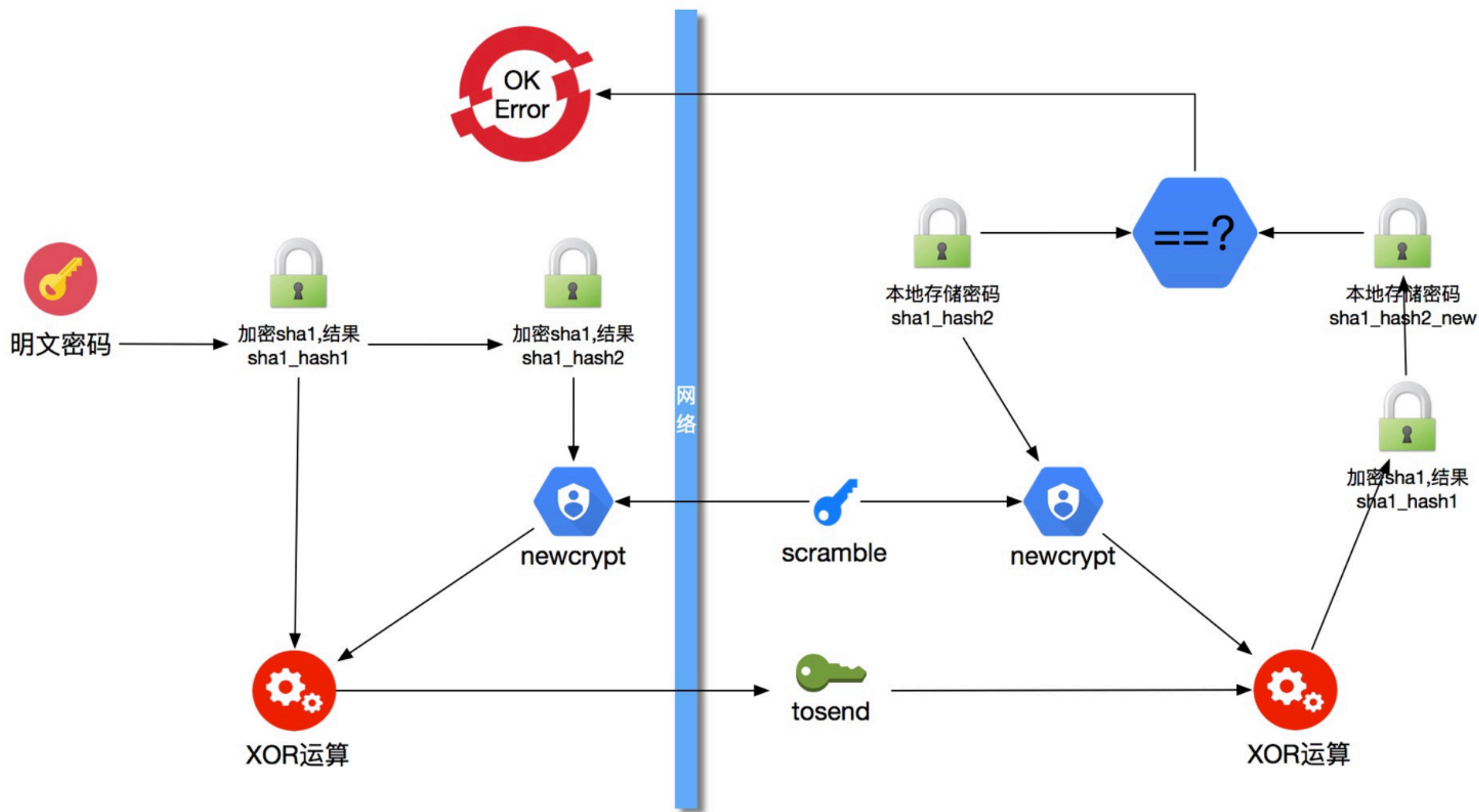
中间层实现方法四 (☆☆☆☆☆) ——不同scramble



思考

中间层实现方法四 (☆☆☆☆☆) ——不同scramble





思考

中间层实现方法四 (☆☆☆☆☆) ——不同scramble

解决了权限放大

无暴露高级账号

真实用户名

IP来源验证

彰显技术实力

中间层需要mysql.user权限

只有中间层IP

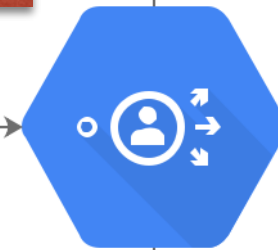
权限验证交给MySQL

客户端用真实账号连接+扩展多节点

安全+完整功能



客户端



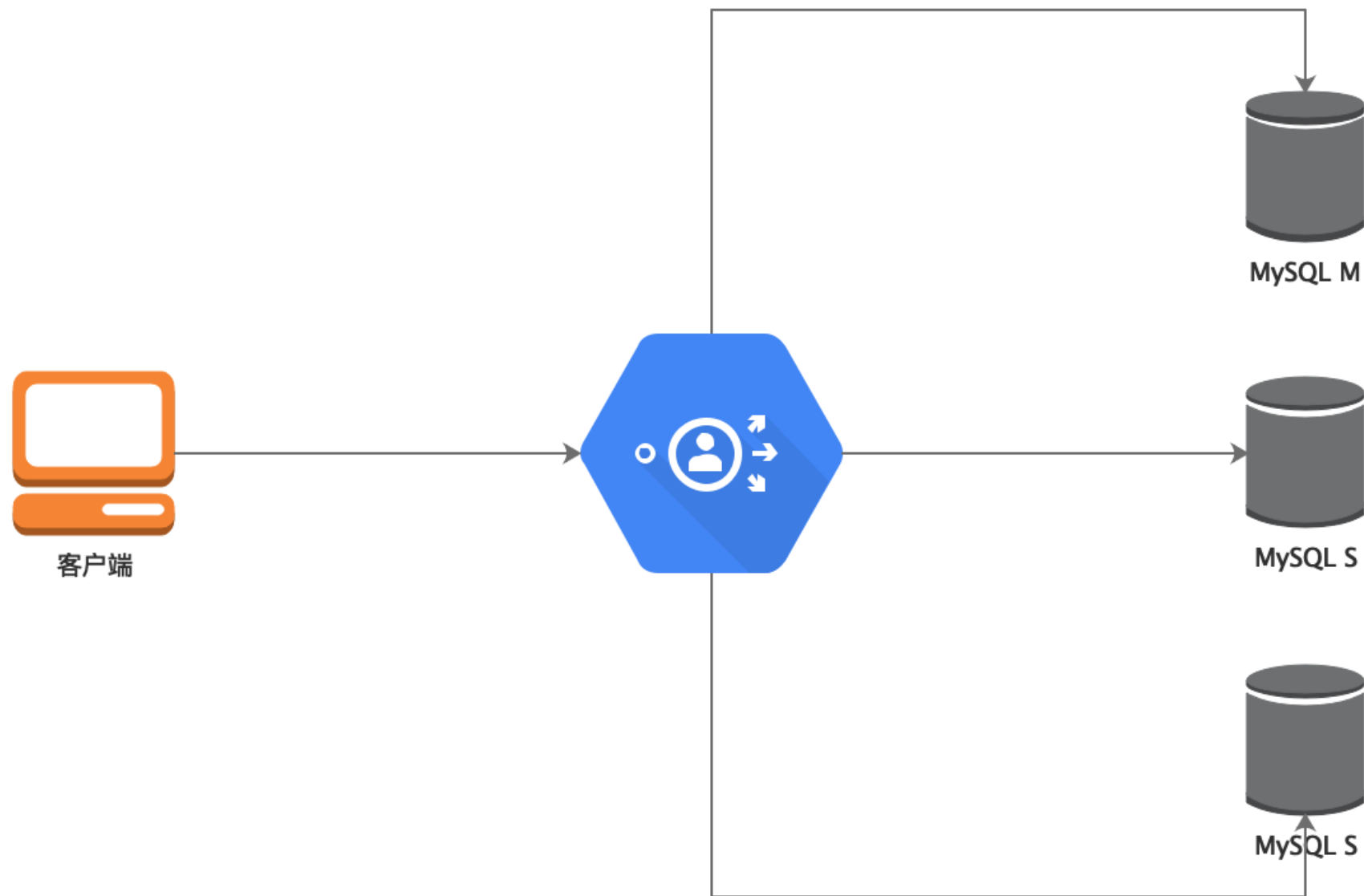
MySQL M

MySQL S

MySQL S

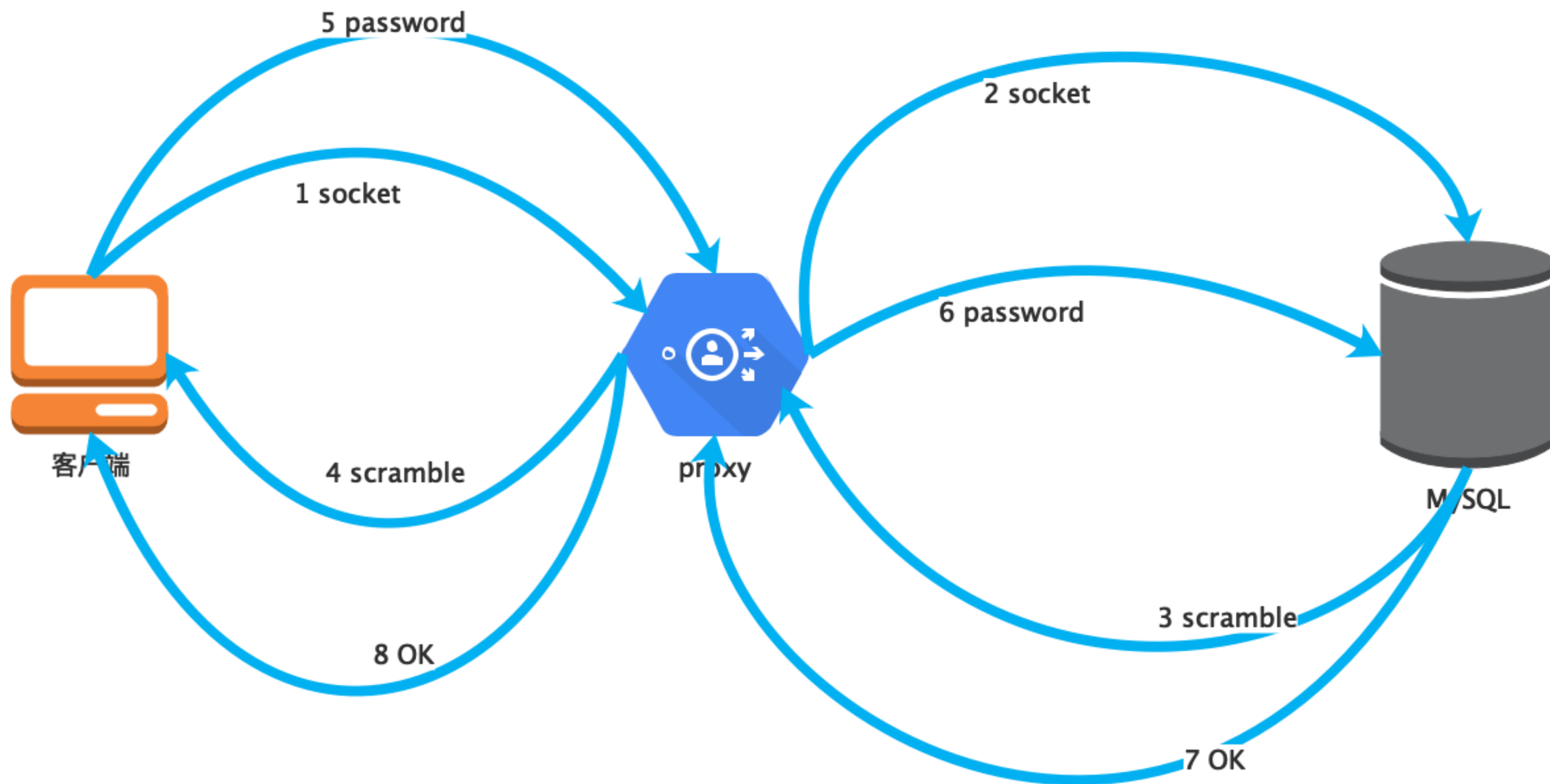
思考

中间层实现方法五 (☆☆☆☆☆) —— 相同scramble



思考

中间层实现方法五 (☆☆☆☆☆) —— 相同scramble



思考

中间层实现方法六 (☆☆☆☆☆)

解决了权限放大

无暴露高级账号

IP来源验证

真实用户名

彰显技术实力

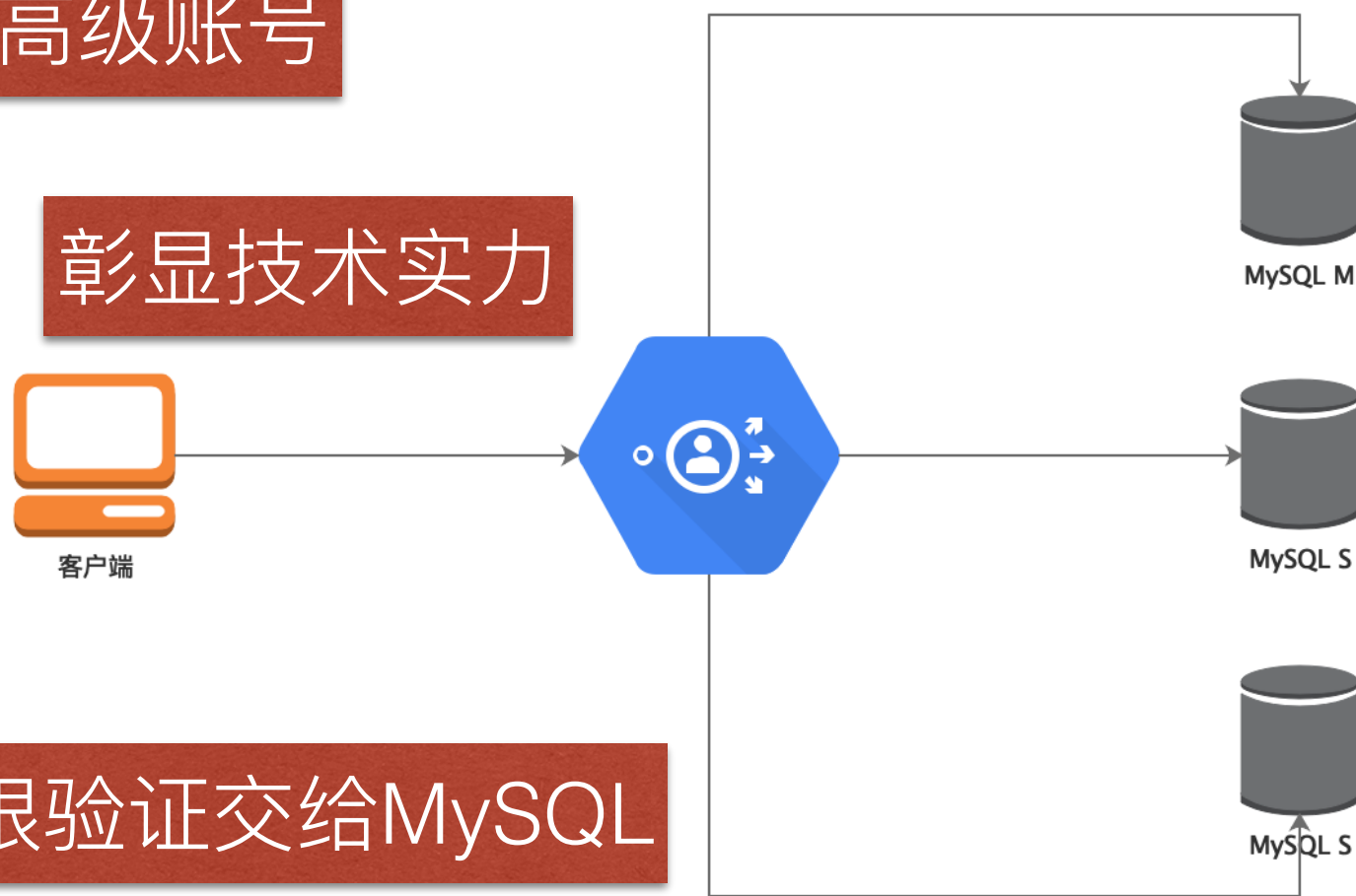
中间层需要简单权限

+能看到真实用户名IP

权限验证交给MySQL

客户端用真实账号连接+扩展多节点

安全+完整功能



思考

▶ 权限没有放大（技术搞定、人为保证？）

▶ 中间层需要的权限

▶ 中间层不知道用户密码

▶ 连接验证可复制

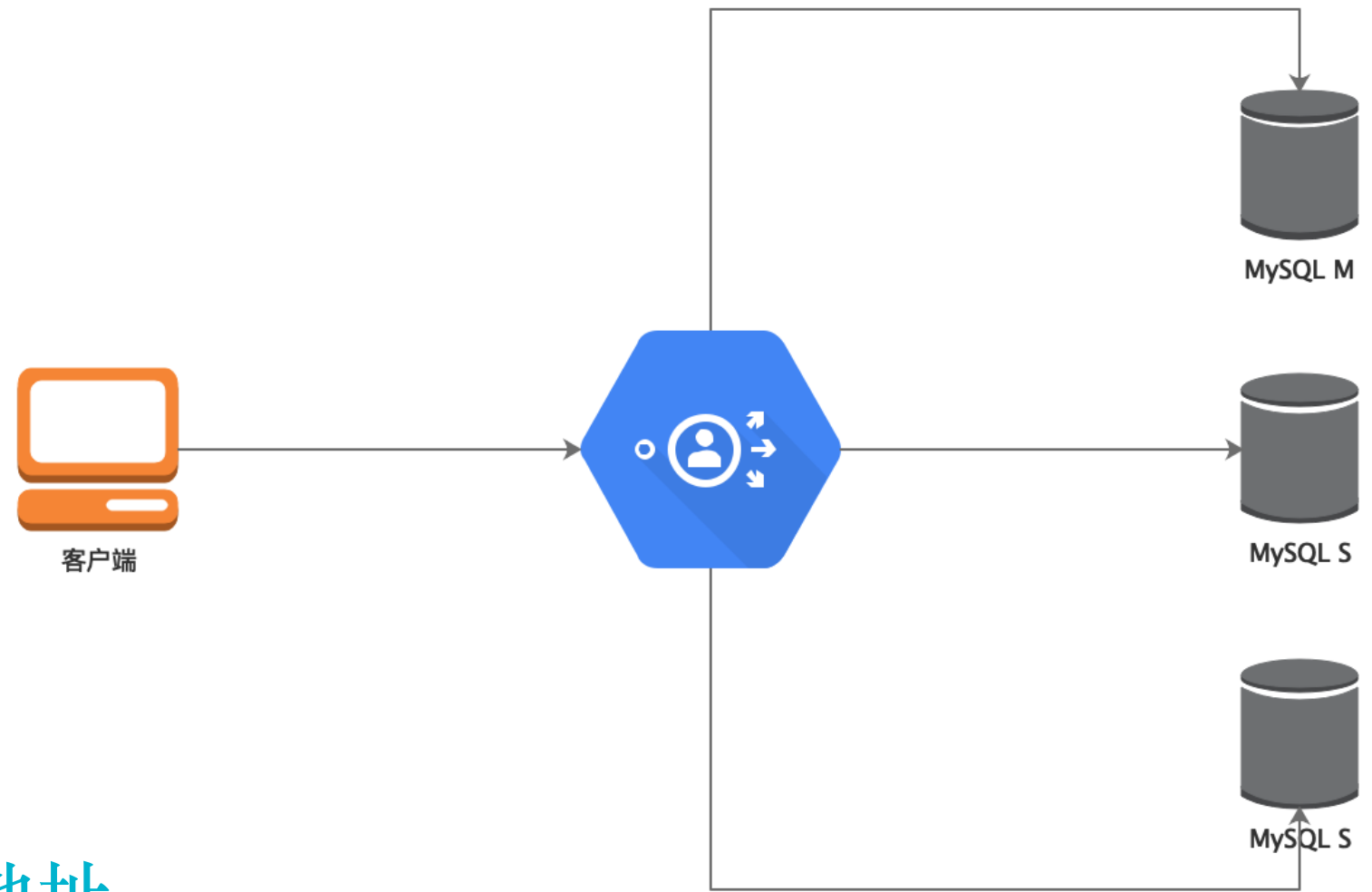
▶ 真正的中间层功能一个不少

▶ 客户端只需真实业务账号

▶ 易维护，简单运维

▶ 中间层不做权限验证

▶ `show processlist`中的来源IP地址



思考

中间层实现方法七 (☆☆☆☆☆☆☆☆☆☆) Percona

+ 最完美

Percona only

Proxy不留任何痕迹

直接上线



客户端



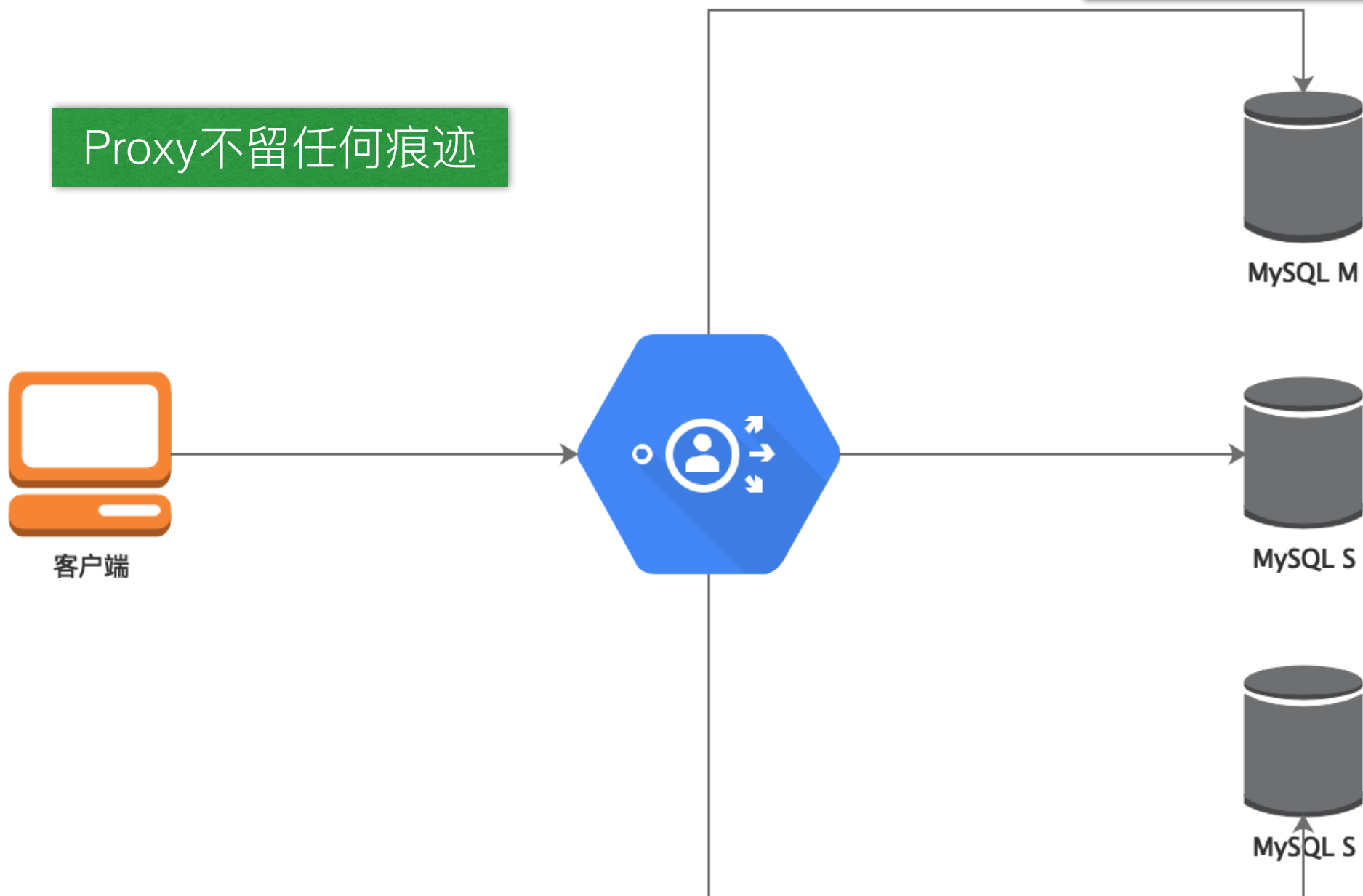
MySQL M



MySQL S



MySQL S



源码学习

<https://github.com/arkdb/arkproxy>

中间层支持多写模式。

1. 开源了。
2. 自动读写分离
3. 100%兼容MySQL
4. Percona无侵入直接上线。
5. 上了中间层性能没有任何损失。（一个节点，多个节点的话性能与节点数据有关系）
6. 使用非常友好，MySQL原生中间件
7. 原生线程池，稳稳的幸福

上线40套+

THANKS

Q&A
